

TASK 01

TASK 01

Report Draft

Title

Critical web vulnerabilities

Findings

CVE-2021-41773 (Apache Path Traversal, CVSS 7.5) — Host: 192.168.1.20. SQL Injection identified via Nikto (CVSS 9.1) — Host: 192.168.1.20. SMB port 445 exposed with no authentication (CVSS 6.5) — Host: 192.168.1.30. Tomcat Manager accessible with default credentials (CVSS 8.8) — Host: 192.168.1.100.

Remediation

1. Patch Apache to $\geq 2.4.51$. 2. Disable unused ports (445, 8080). 3. Change all default credentials immediately. 4. Implement WAF rules for SQLi prevention. 5. Rescan after patching to verify closure.

Analyst

VAPT Analyst | CyArt Team

Escalation Email

To: developers@example.com

Cc: security-team@example.com

Subject: [VAPT] Critical RCE vulnerabilities – action required by 2025-05-18

Dear team,

During our vulnerability assessment of 192.168.150.129, we discovered three actively exploitable flaws that give attackers instant remote root access:

1. vsftpd backdoor (CVE-2011-2523) – any connection to port 21 returns a root shell.

2. Tomcat default credentials (`tomcat:tomcat`) – allows arbitrary Java code execution.
3. UnrealIRCd backdoor – remote code execution on port 6667.

Proof of Concept (Metasploit) – attached logs show successful `/bin/bash` as root without any password.

Remediation deadline: 48 hours – replace vsftpd with openssh or disable it entirely. Remove Tomcat default users and set strong passwords. Block ports 6667 & 8080 from public access.

Please confirm once fixes are applied so we can rescan.

Regards,

VAPT Analyst Team

TASK 02

TASK 02

OSINT on 192.168.150.129 revealed a legacy Linux server running Apache 2.2.8, Tomcat 5.5, vsftpd 2.3.4, and UnrealIRCd. No external domain ownership but multiple high-risk services were exposed. Shodan confirmed open ports 21, 22, 23, 80, 8080, 6667, 445.

TASK 03

TASK 03

The Tomcat Manager default credentials tomcat:tomcat remain unchanged on Metasploitable2. Metasploit's tomcat_mgr_login auxiliary module successfully discovered these credentials, and the tomcat_mgr_upload exploit delivered a Java reverse shell. This attack chain demonstrates that default credentials provide a trivial foothold, leading to complete application compromise.

Remediation Recommendations

Remove Default Credentials: Modify the tomcat-users.xml file to replace default entries (e.g., tomcat:tomcat, admin:admin) with strong, unique passwords, and remove the manager-gui role unless strictly required.

Restrict Manager Access: Bind the Tomcat Manager application to localhost (127.0.0.1) or implement IP-based allowlisting to restrict administrative interface exposure.

Principle of Least Privilege: Assign the minimal necessary role (manager-status or manager-script) rather than the all-powerful manager-gui.

Regular Credential Audits: Periodically audit Tomcat installations for weak or default credentials using automated scanners.

WAR File Validation: Implement controls to restrict WAR file uploads and scan all uploaded applications for malicious code.

TASK 05

TASK 05

PTES Report

Executive summary: A full penetration test following PTES identified critical SQL injection and XSS flaws in the DVWA web application. Attackers could extract entire databases or hijack user sessions. Exploitation using sqlmap retrieved password hashes and credit card numbers from the simulated “users” table. Post-exploitation revealed that the web server ran as root, allowing full system compromise. Recommendations: implement prepared statements, apply CSP headers, and run web server with non-privileged user.

Non-Technical Briefing

Our security team performed a controlled attack simulation on your web application. We found two serious issues: SQL injection (allows hackers to steal your entire database) and cross-site scripting (lets attackers impersonate users). Using automated tools we were able to extract sensitive data like login credentials within minutes. The good news is these problems are fixable: your developers need to add input validation and use prepared SQL statements. We also recommend running the web server under a low-privileged account. After implementing these fixes, we will re-test to confirm security. No customer data was harmed during this exercise.